

Periapt: Know Which Flaw Matters First

The Business of AI • Mid-Semester Assignment • [Name, Roll No.]

2 a.m. A security advisory lands: a flaw in the ground mission-control software could let an attacker send commands to the fleet, and the vendor has no patch yet. The CISO of a mid-size satellite operator thinks of 200 satellites. Some are new; some have flown for years on tired batteries; even two launched together sit in different sun, eclipse, radiation and workload, so the same command can do very different damage. Security, flight software and mission operations each hold part of the answer. Which satellites are most at risk tonight, and what can safely be done before the fix? Tomorrow another advisory arrives and the question returns: **which flaw first, and why?** (*Illustrative scene.*)

1. Company Overview

Brand. A *periapt* is a protective amulet, and the name echoes *periapsis*, an orbit's closest point: protection at the closest point of risk. **Mission:** tell every operator, within minutes of a new flaw, what it means for each satellite, with reasons they can check. **Vision:** the trusted decision layer for every spacecraft operator, starting small and growing as trust is earned.

Where it sits. On Gartner's AI stack, Periapt is a Layer 6 application that delivers Layer 7 (AI Security & Risk) outcomes, the layer where the course places CrowdStrike, whose Charlotte AI helps analysts triage. In Foundation Capital's terms it is domain-specific AI: its value is knowing satellites, not owning a model. It sells B2B to operators, and B2B2G where those operators serve US defence customers.

Market. 14,266 satellites were operating at the end of 2025, and 4,434 were deployed in 2025 alone, 65% more than in 2024 (SIA, 2026). That growth is mostly mega-constellations, so Periapt targets mid-size operators. No official figure exists for this niche, so we estimate it ourselves by summing the fleets of the five named mid-size buyers in a public tracker (Planet, Iridium, SES, Intelsat, ICEYE): about 430–450 satellites. For scale, the commercial satellite industry is worth \$303B (SIA, 2026).

Why now. Published vulnerabilities (CVEs) rose from 40,009 in 2024 to 48,185 in 2025, with 57,908 already in 2026 up to 31 August. Scanners match known CVEs to listed software; what stays manual is judging what a flaw means for each satellite. Attackers need no exotic tricks: at Viasat in 2022 they entered through a misconfigured ground VPN appliance and sent *legitimate* management commands, and Viasat shipped nearly 30,000 modems to recover. Machine learning already forecasts which IT flaws will be exploited (FIRST's EPSS), and research simulates attacks on satellites, but we found no product that predicts, automatically and per satellite, what a flaw would do. **Topic fit:** day zero is the day a flaw becomes known, often before a patch exists. Space is not one of the 16 US critical infrastructure sectors, but critical sectors depend on it: the Viasat outage cut remote monitoring of about 5,800 wind turbines, and the EU lists space as a high-criticality sector.

2. Agentic AI and Value Proposition

The workflow. Periapt runs vulnerability triage: it turns each new advisory into a ranked, explained decision for the security, flight-software and mission-operations teams, in three layers, using AI only where rules cannot reach (Table 1, Figure 1).

Layer	Question it answers	How	What the team gets
1. Exposure	Which of our satellites carry this flaw, and can an attacker reach them?	LLM proposes matches; a plain rule confirms each against a cited parts-list line; a reach map traces ground → spacecraft paths	Satellites that scanners miss (prose advisories, no parts list), each with proof, and only those an attacker can reach
2. Likelihood	How severe is it, and how likely is an attack soon?	CVSS, EPSS, SPARTA: reused, not rebuilt	Scores the team already knows and trusts
3. Mission impact	What would it do to each satellite right now?	Periapt's world model	The same flaw ranked differently per satellite, so the one hurt most is fixed first

Table 1. Three layers: rank = likelihood × mission impact, for exposed satellites only.

This fills in the method operators already use (Spire ranks vulnerabilities by ISO 27005 likelihood and impact) rather than replacing it.

The two AI parts. A self-hosted LLM agent reads advisories, including prose ones, proposes matches, writes briefs and orchestrates the work. A **world model**, learned per fleet from telemetry and command history (state + command → next state), plays out "what if these commands were sent?". JEPA-style is our candidate design; JPL's LSTM model

of spacecraft telemetry (Hundman et al., 2018) is the precedent and the baseline to beat. The commands come from the flaw: the advisory says what access it gives, the reach map says which satellites that access can command, and the operator's own command list, narrowed to matching SPARTA attack techniques, gives the candidate sequences. The worst predicted outcome becomes each satellite's impact score: "heaters off" should hurt an old satellite entering eclipse on a weak battery far more than a new one in sunlight. The model also aims to forecast battery and thermal margin, so a suggested fix window is safe. One **authority rule** governs it: the AI may raise a priority on its own, lowering one needs a human, and anything outside the model's data counts as high.

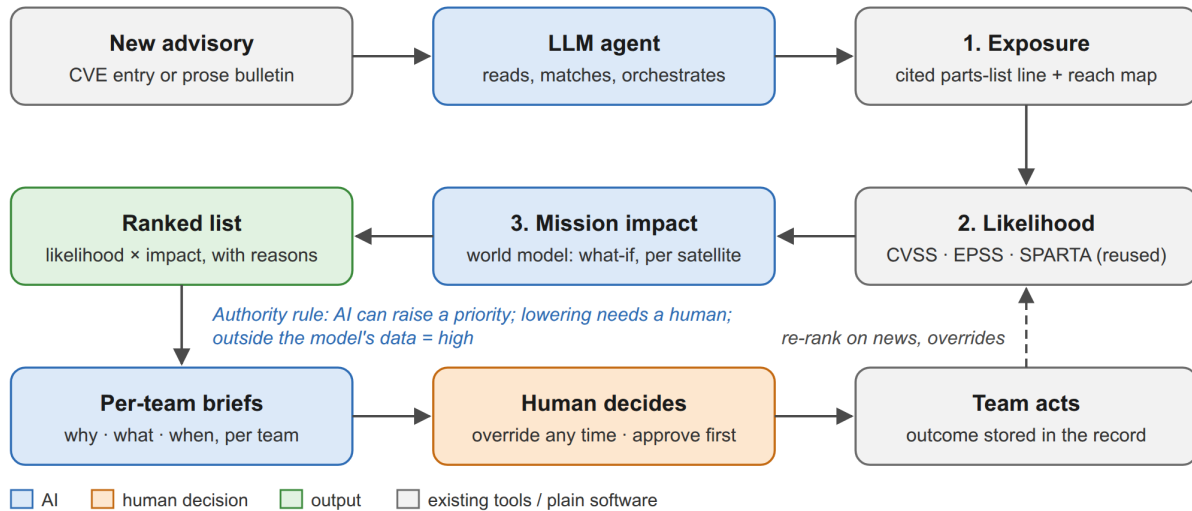


Figure 1. The agentic loop: it runs alone up to the ranking; humans override any time and approve before any action.

Why it is agentic. One orchestrator works ReAct-style (reason, call a tool, observe) across six tools: parts list, reach map, scores, SPARTA, world model and tickets. It perceives, processes, decides and acts, re-ranks when news or an override arrives, and records the outcome after the team fixes a flaw; Periapt never tests or sends a fix itself.

Value. Teams gain coverage (every advisory against every satellite), memory (the record outlives staff turnover), consistency at 2 a.m., and translation: security gets the *why*, flight software the *what*, operations the *when*. A general chatbot cannot trace reach or play out commands, and pasting fleet data into one is shadow AI. The gains are **efficiency** (analyst hours, time to decision), **risk** (fewer critical flaws missed, evidence behind every approval) and **innovation** (evidence packs that give defence audits a method for NIST SP 800-171's undefined "timely"). A rough starting estimate, with assumed inputs to be measured in the pilot: 20 relevant advisories a week × 3 analyst-hours × half handled alone saves about 30 hours a week, 0.75 of an analyst, or roughly \$85K–120K a year at general-industry salaries. A lost smallsat, about \$0.5–1M to replace, shows what is at stake but is not counted.

Proof. Five tests decide whether the world model earns its place: beating JPL's LSTM on ESA's anomaly benchmark (fewer false alarms at equal detection); predicted versus actual telemetry after real commands; predicted versus simulator impact on replayed attacks; agreement with the team in shadow mode; and a backtest on past advisories. If it loses to the simpler forecaster, only the model changes.

3. Moat and Defensibility

Core product architecture. The loop in Figure 1 runs on four features: an **onboarding kit** (forward-deployed engineers build the parts list and reach map with the customer); the **authority rule**, enforced in software; **per-team briefs and tickets** inside each team's own tools; and **the record** of every flaw, ranking, override and outcome per satellite. The world model has a shared base trained only on public data and open simulators, plus a thin layer per fleet trained on that customer's data. Any model can be swapped in, so Periapt would survive a model change tomorrow: the model is not the moat.

The moat is earned trust. Experts rely less on automation (Sanchez et al., 2011), so trust is built slowly in shadow mode and kept only while the rankings stay right. It is an intangible asset, a brand earned one customer at a time, and staying builds the rest: **the record in use** (it feeds each ranking, its overrides train the fleet layer, and it backs every audit), a **workflow switching cost**, and **value that should grow with time in orbit** as satellites drift apart (how fast is a pilot metric).

Who owns what. The customer owns its telemetry, command history and record, and can export them. Periapt owns the base model and software and licenses the fleet layer only during the subscription; it is deleted on exit, useless

without our base, and stale as satellites age. A customer who leaves keeps its data but loses a working system; a rival, or its own team, must rebuild the models and integrations and win the experts' trust again.

Market structure. Efficient scale protects us, since few rivals chase a niche this small, but it also caps growth, so the longer path runs abroad, starting with allies where export rules allow. A cross-fleet network effect is possible only through opt-in, minimum-data sharing on the Space Data Association model. Public data and manufacturer ties are not moats. Honestly, the moat is thin at first, and one missed critical flaw can cost it.

4. Porter's Five Forces

Strategic point: be the neutral commercial layer that builds on public tools (SPARTA, EPSS) and plugs into each operator's own. Every force pushes towards integrating, not replacing (Table 2).

Force	Rating (high = bad for us)	Evidence	What Periapt does
Buyers	High	The five named buyers are few and capable, all with formal security programs; SES alone has over 40 security professionals. Globalstar is out (acquisition by Amazon)	A copilot that fills in their method, with evidence they can audit
Suppliers	Medium	Manufacturer data is concentrating as primes buy up makers; telemetry is the customer's own; public feeds and open-weight LLMs are freely available	Build parts lists with the customer; self-host an open-weight model
Rivalry	Low (high for IT)	No one publicly ranks flaws by impact per satellite; Tenable, Qualys and Nucleus crowd general IT ranking	Use their output; don't sell IT ranking
Substitutes	High	The good-enough stack: in-house team + ISO 27005 + scanners with EPSS + SPARTA	Plug into it and prove hours saved
New entrants	High	Google (already working with Aerospace), the primes, Booz Allen, Deloitte	Move first with a commercial, unclassified, US-person team; a cleared partner later

Table 2. Five Forces: four of five are against us, so the strategy is to integrate, not fight.

The closest neighbours are named so the originality claim stays honest: Aerospace Corporation's SPARTA framework and SPARTEND on-orbit detection; Aerospace and Google's agentic anomaly monitoring for large constellations; CT Cubed's IRON GALAXY assessments and cyber ranges; Deloitte's Silent Shield (detection); and Spire's rollout platform. Spire is co-opetition: operator, manufacturer and tooling vendor at once. None publicly ranks flaws by predicted impact per satellite, though absence of public claims is not proof (the streetlight effect). **Aerospace is a partner, not a rival:** under FAR 35.017 a federally funded research centre is not meant to use its privileged access to compete with the private sector, and its ASC-100 testbed is a validation route. **Regulation cuts both ways:** no US rule mandates flaw prioritisation, but NIST SP 800-171 (3.14.1) tells defence contractors to "identify, report, and correct system flaws in a timely manner" without defining *timely*, which makes them our beachhead. **Net:** a hard industry for a generic tool, but workable for a neutral layer with a shared core, configured (not custom-built) to each operator.

5. Persona and Customer Journey

The Stretched Sentinel	CISO / VP Security at a mid-size operator that also serves US defence customers: the CISO from our 2 a.m. scene. Grounded in Planet's 2026 VP & CISO posting, where one role spans cyber, compliance and AI governance.
In their words	"I don't need another dashboard. I need to know which flaw to fix first, and be able to prove why." (illustrative)
Pains	Advisory overload; audit pressure; blame for the one flaw that was missed
Goals	Defend the fleet; show auditors a method
Decision criteria	Evidence behind every ranking; auditability; never touches the command path; fits the tools the team already has
Psychographic	An expert, and so sceptical of automation

Table 3. Persona card.

Buying committee. The CISO holds the budget; a security analyst is the daily user and champion; the flight-software lead can block adoption if the briefs are wrong; the mission-ops lead approves anything that touches a satellite. The category is at the introduction stage of its life cycle, so we sell to **early adopters** (Diffusion of Innovation): operators with formal programs, defence customers and fleets with years in orbit, where the world model has most to say.

Prepurchase	Purchase	Shadow	Assist	Show	Renew
Advisory overload plus a trigger: an audit or an incident	Paid pilot; onboarding kit builds parts list and reach map	Rankings beside the team's own while the model trains	Low-impact flaws auto-triaged and ticketed; humans own the top	Evidence packs for board, insurer and DoD auditor	On hours saved, time to decision, no critical flaw missed
Trigger	Data capture	Classification	Delegation	Social	Loop to Stage 2

Table 4. Journey strip: Lemon & Verhoef's stages (columns) with Puntoni et al.'s AI experiences (last row).

The journey is built to escape the pilot trap (Gartner: over 80% of enterprise AI initiatives stall at pilot). Satisfaction, performance above expectations, drives renewal (Kumar et al., 2019), and the 2 a.m. fear turns into confidence one ranking at a time. Assumed timeline: paid pilot, about one quarter in shadow mode, assisted triage, renewal at 12 months.

6. Governance, Guardrails and US Compliance

Tier	What	Who
Runs alone	Ingest, match, score, what-if, rank, brief, ticket, re-rank	The agent
Override, any time (on the loop)	Change any ranking, logged with a reason	Any team
Approval (in the loop)	Any action touching a satellite or ground system	Mission-ops lead / system owner
Never automated	Changes to the command, boot or authentication path	Humans only

Table 5. Where humans sit.

When the AI stops or escalates. No cited parts-list line: a human decides. Outside the model's data: "impact unknown", ranked high. Conflicting advisories: escalate. Anything touching command authentication or the boot path: top priority, humans only. Drift (predictions stop matching telemetry): layer 3 pauses and ranking falls back to layers 1–2. A **kill switch** does the same on demand.

Reliability and AI security. Every match cites its source line and passes a rule check, and outputs are structured and validated, which guards against hallucination. Advisories are untrusted input, so their text is treated as data, never as instructions (prompt injection). The agent has **least privilege**: it reads telemetry and writes tickets, with no route to command systems. Against **model poisoning**, training data and overrides are vetted, and every retrained model must pass a release test in simulation, including a fixed set of known critical flaws it must still rank high; because the AI can only raise priorities, a poisoned model cannot push a flaw below the standard scores. It never acts alone because being everywhere cuts both ways: one bad CrowdStrike update hit 8.5 million Windows devices in 2024.

Monitoring and audits. Drift checks as satellites age (Zillow's pricing model failed when its market shifted); an audit trail on NIST SP 800-53 AU-2/3/6, reviewed at least weekly (Cruise lost a permit partly over missing records); model cards; and a periodic safety review that reruns the five tests, including a **bias** check that data-poor satellites are not under-ranked. **Liability:** Periapt is decision support with a stated residual risk, never "certified safe"; Air Canada was held to its chatbot's words, so our claims stay careful.

US compliance. The NIST AI RMF maps cleanly (NIST, 2023): *Govern*, who owns overrides and approvals; *Map*, the rank-versus-act boundary; *Measure*, the tests and drift; *Manage*, stop rules and the kill switch. Under **CCPA**, almost all data is machine telemetry; the only personal data is staff names in the audit trail, handled as a service provider. **FTC** exposure is mainly overstated claims. **Sector rules:** export controls (EAR 9A515, ITAR where it applies) mean only US persons handle customer technical data, and NIST SP 800-171 governs defence work (NIST, 2020). On exit, the fleet layer and our copy of the data are deleted, cleanly, because the shared base holds no customer data. Trust rests on competence (the tests), integrity (the audit trail) and benevolence (no route to commands) (Pavlou & Fygenson, 2006), aiming for calibrated trust between distrust and over-trust (Lee & See, 2004).

7. Four Lenses, and 2 a.m. Again

Feasibility: layers 1–2 use proven tools and learned spacecraft models exist; the open question, damage from never-seen command sequences, is settled by the tests, and if it fails Periapt still ranks on exposure and scores. **Usability:** it fits each team's tools and method. **Desirability:** capable teams face rising volume and an undefined "timely"; Periapt supports them as a copilot and does not replace them. **Viability is the biggest risk:** a small buyer pool, people-heavy onboarding, slow trust-based sales, compliance and model upkeep. We manage it with an onboarding fee for each new fleet or satellite design, a per-satellite subscription that grows with the fleet (as CrowdStrike prices per

endpoint), configuration rather than custom builds, and staged growth abroad. **Think big, act small:** Stage 1 ranks; Stage 2 adds fix planning, outcome tracking and feedback; Stage 3 adds testing the teams' fixes and rollout with partners, each once trust is earned.

2 a.m., again. By 2:10 the CISO has a ranked list. Satellite 12 is first: reachable from the ground, and "heaters off" would hurt it most in tonight's eclipse. The CISO approves the work-around the flight-software brief suggests and goes back to sleep. Which flaw first, and why? Now there is an answer anyone can check.

Key References

1. Satellite Industry Association (2026). *29th State of the Satellite Industry Report*. SIA.
2. NIST (2020). *SP 800-171 Rev. 2: Protecting Controlled Unclassified Information in Nonfederal Systems and Organizations*. National Institute of Standards and Technology.
3. NIST (2023). *AI 100-1: Artificial Intelligence Risk Management Framework (AI RMF 1.0)*. National Institute of Standards and Technology.
4. Hundman, K., Constantinou, V., Laporte, C., Colwell, I., & Soderstrom, T. (2018). Detecting Spacecraft Anomalies Using LSTMs and Nonparametric Dynamic Thresholding. *Proc. ACM SIGKDD (KDD '18)*.

Course frameworks cited in text: Porter; Lemon & Verhoef (2016); Puntoni et al. (2021); Lee & See (2004); Pavlou & Fygenon (2006); Sanchez et al. (2011); Kumar et al. (2019); Gartner AI stack; Foundation Capital; Morningstar moat sources.

Appendix: Thinking and AI Use

1. Working evidence: two decision trees from my notes (Q numbers refer to my challenge log).

What is the moat?

Cross-fleet network effect (Q10)

- └ Enough shared failures to learn from? No, they're rare (Q13)
- └ Public data? Proves feasibility for everyone, so not a moat (Q18)
- └ Pooled data? Operators won't help rivals (Q22): only conditional
- └ The customer's own data? It's theirs and leaves with them (Q40)
 - └ What keeps them? Earned trust ✓; record, workflow, value follow (Q43)
 - └ Who owns the model? Base ours; fleet layer licensed, deleted on exit ✓

Where should the AI sit?

Predict patch effects ✗ new code is outside the model's data

- └ Judge emulator test runs? Works, but a commodity (Q33)
- └ Predict each flaw's impact per satellite ✓ (Q36)

2. AI tools. Claude Code (Opus) was my main thinking partner: brainstorming, a logged challenge-and-answer record (Q1–Q49), the report blueprint, and a tagged first draft that I rewrote in my own words. Claude subagents ran seven sourced research threads and a red-team review that listed 35 weak claims. My rule: no number is used unless it is in the findings file; a verification pass corrected my Viasat story (a misconfiguration, not an unpatched flaw). Transcript 1: [Google Drive link]. Transcript 2: [Google Drive link].

3. The hardest concept: what should the AI actually predict? I considered three options. *What a patch will do* was rejected: a patch is new code, outside anything the model has seen. *A judge of emulator test runs* works, but emulators already exist, so it is a commodity. *Each flaw's impact on each satellite* was chosen: attacks misuse commands the model has seen in normal operations, the answer differs per satellite, and it is exactly the listed topic's "prioritisation". The trade-off is that it is the least proven, so it comes with named tests and the rule "unknown = high". That choice raised a second hard question: if the model learns from each customer's telemetry, the data is theirs, so what is our moat at all? Working it through (the first tree) moved the moat from data to earned trust and split the model into a shared base we own and a thin, licensed fleet layer.

4. Accepted, modified, rejected, independently developed.

Accepted	The satellite niche inside Day-Zero Vulnerability Prioritisation; mid-size operators as the target; reusing EPSS and SPARTA instead of rebuilding them
Modified	Moat: network effect → earned trust as the root, with a base/fleet-layer split; world model: judging patches → predicting flaw impact; Aerospace Corp: rival → complement; scope: the whole flaw-to-fix pipeline → prioritisation only
Rejected	Generic vulnerability management (not novel); AI-written patches sent to satellites; an RL planner; customer telemetry as the moat; a revenue figure without evidence
Independently raised by me	Regulation cuts both ways; public data isn't a moat; in-house teams; why help competitors; unit economics; undo = unreliable; scope drift away from AI; replacement vs assistance; topic fit; autonomy; Aerospace as a complement; matching is already automated; market size as a labelled estimate; what each layer gives the team; trust as the root of the moat and who owns the model; configured, not custom; a persona not bound to the US; model poisoning tested in simulation; onboarding per new fleet